ETSI TR 103 331 V1.2.1 (2019-09)



CYBER;
Structured threat information sharing

Reference
RTR/CYBER-0032

Keywords
security, threat analysis, threat intelligence

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - NAF 742 C
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° 7803/88

Important notice

The present document can be downloaded from:
http://www.etsi.org/standards-search

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format at www.etsi.org/deliver.

Users of the present document should be aware that the document may be subject to revision or change of status.
Information on the current status of this and other ETSI documents is available at
https://portal.etsi.org/TB/ETSIDeliverableStatus.aspx

If you find errors in the present document, please send your comment to one of the following services:
https://portal.etsi.org/People/CommiteeSupportStaff.aspx

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI.
The content of the PDF version shall not be modified without the written authorization of ETSI.
The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2019.
All rights reserved.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members.
3GPP™ and **LTE™** are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners.
oneM2M™ logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners.
GSM® and the GSM logo are trademarks registered and owned by the GSM Association.

Contents

Intellectual Property Rights 4
Foreword 4
Modal verbs terminology 4
Executive summary 4
Introduction 5
1 Scope 6
2 References 6
2.1 Normative references 6
2.2 Informative references 6
3 Definition of terms, symbols and abbreviations 7
3.1 Terms 7
3.2 Symbols 8
3.3 Abbreviations 8
4 Means for exchanging structured cyber threat intelligence 9
4.1 Introduction 9
4.2 OASIS Cyber Threat Intelligence Technical Committee (TC CTI) 9
4.2.1 Introduction 9
4.2.2 STIX 2.0 10
4.2.3 STIX 2.1 11
4.2.4 Adversarial Tactics, Techniques and Common Knowledge in STIX 2.0 12
4.2.5 TAXII 2.0 12
4.3 IETF Managed Incident Lightweight Exchange Working Group (mile) 13
4.4 CSIRTGadgets Collective Intelligence Foundation (CIF) 14
4.5 EU Advanced Cyber Defence Centre (ACDC) 14
4.6 AbuseHelper 15
4.7 OMG Threat Modelling Working Group 15
4.8 ITU-T SG17 15
4.9 Open Threat Exchange™ (OTX™) 16
4.10 OpenIOC Framework 16
4.11 VERIS Framework 16
4.12 ETSI ISI (Information Security Indicators) ISG 16
4.13 OASIS Common Security Advisory Framework (CSAF) Technical Committee 17
Annex A: Bibliography 18
History 19

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The information pertaining to these essential IPRs, if any, is publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI Web server (https://ipr.etsi.org/).

Pursuant to the ETSI IPR Policy, no investigation, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

Some material contained herein is the copyright of, or has been supplied by OASIS.

Figures 4.1, 4.2, 4.3, 4.4, 4.5, 4.6, 4.7 copyright © OASIS Open 2017. All Rights Reserved.

Figures 4.1, 4.2, 4.3, 4.4, 4.5, 4.6, 4.7 copyright © United States Government 2016-2018. All Rights Reserved. Used by permission.

Foreword

This Technical Report (TR) has been produced by ETSI Technical Committee Cyber Security (CYBER).

Modal verbs terminology

In the present document "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

Cyber threat information sharing - often described as threat intelligence sharing - is one of the most important components of an organization's cyber security program. It can be obtained internally and from external trusted sources. It is collected, analysed, shared, and leveraged. The present document provides a survey of ongoing activities and the resulting platforms that are aimed at structuring and exchanging cyber threat information. These activities range from those developed among the Computer Emergency Response Teams in the 1990s in the IETF, to cutting-edge new initiatives being advanced in OASIS. Some of the platforms are semi-open commercial product communities. It is possible that the OASIS CTI work could bring about significant interoperability if not integration in this area.

Introduction

The importance of cyber threat information sharing has been underscored recently by the European Union and North America enacting into organic law, combined with major executive level and national initiatives. These actions extend across all information, and infrastructure sectors. Some of the more prominent of these recent actions include:

- EU Network Information Security Directive, approved 18 December 2015 [i.1].
- Cybersecurity Information Sharing Act of 2015 (18 December 2015) [i.2].
- CPNI, Threat Intelligence: Collecting, Analysing, Evaluating, 23 March 2015 [i.3].
- Launch of the Canadian Cyber Threat Exchange, 11 December 2015.

Against this backdrop of initiatives that included the scaling of Financial Services Information Sharing and Analysis Center (FS-ISAC) and The Depository Trust & Clearing Corporation (DTCC) activities, the OASIS Cyber Threat Intelligence Technical Committee was formed in 2015 to bring together a broad and rapidly growing array of public and private sector organizations to advance a global set of standards for structured threat information sharing.

The present document describes the known array of existing structured threat information sharing work in diverse bodies, including the developments underway in OASIS TC CYBER which can form the basis for expanded cooperation based on existing ETSI and OASIS collaborative agreements and working relationships among Technical Committees.

1 Scope

The present document provides an overview on the means for describing and exchanging cyber threat information in a standardized and structured manner. Such information includes technical indicators of adversary activity, contextual information, exploitation targets, and courses of action. The existence and creation of organizations for the exchange of this information are out of scope the present document.

2 References

2.1 Normative references

Normative references are not applicable in the present document.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are not necessary for the application of the present document but they assist the user with regard to a particular subject area.

[i.1] Directive of the European Parliament and of the Council concerning measures with a view to achieving for a high common level of security of network and information security systems across the Union, Brussels, 21 April 2016 (5581/16).

[i.2] Guidance to Assist Non-Federal Entities to Share Cyber Threat Indicators and Defensive Measures with Federal Entities under the Cybersecurity Information Sharing Act of 2015 (June 2016).

NOTE: Available at https://www.us-cert.gov/sites/default/files/ais_files/Non-Federal_Entity_Sharing_Guidance_%28Sec%20105%28a%29%29.pdf.

[i.3] National Cyber Security Centre: "Threat Intelligence: Collecting, Analysing, Evaluating", October 2016.

NOTE: Available at https://www.ncsc.gov.uk/content/files/protected_files/guidance_files/MWR_Threat_Intelligence_whitepaper-2015.pdf.

[i.4] OASIS Specifications, STIX 2.0, TAXII 2.0.

NOTE: Available at https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=cti.

[i.5] Internet Engineering Task Force (IETF): "Managed Incident Lightweight Exchange (mile) Working Group".

NOTE: Available at https://datatracker.ietf.org/wg/mile/documents/.

[i.6] Recommendation ITU-T X.1500-Series: "Cybersecurity information exchange".

NOTE: Available at https://www.itu.int/itu-t/recommendations/index.aspx?ser=X.

[i.7] ETSI ISG ISI (Information Security Indicators) initial Terms of Reference.

NOTE: Available at https://portal.etsi.org/ISI/ISI_ISG_ToR_Sep2011.pdf .

[i.8] ETSI GS ISI 001-1: "Information Security Indicators (ISI); Indicators (INC); Part 1: A full set of operational indicators for organizations to use to benchmark their security posture".

[i.9] ETSI GS ISI 001-2: "Information Security Indicators (ISI); Indicators (INC); Part 2: Guide to select operational indicators based on the full set given in part 1".

[i.10] ETSI GS ISI 002: "Information Security Indicators (ISI); Event Model A security event classification model and taxonomy".

[i.11] ETSI GS ISI 003: "Information Security Indicators (ISI); Key Performance Security Indicators (KPSI) to evaluate the maturity of security event detection".

[i.12] ETSI GS ISI 004: "Information Security Indicators (ISI); Guidelines for event detection implementation".

[i.13] ETSI GS ISI 005: "Information Security Indicators (ISI); Guidelines for security event detection testing and assessment of detection effectiveness".

[i.14] IETF RFC 5070: "The Incident Object Description Exchange Format".

[i.15] IETF RFC 6545: "Real-time Inter-network Defense (RID)".

[i.16] IETF RFC 6546: "Transport of Real-time Inter-network Defense (RID) Messagesover HTTP/TLS".

[i.17] Void.

[i.18] Void.

[i.19] Void.

[i.20] Void.

[i.21] IETF RFC 6046: "Transport of Real-time Inter-network Defense (RID) Messages".

[i.22] Void.

[i.23] Void.

[i.24] Void.

[i.25] Void.

[i.26] Void.

[i.27] ISO/IEC 27001: "Information technology -- Security techniques -- Information security management systems -- Requirements".

[i.28] ISO/IEC 27002: "Information technology -- Security techniques -- Code of practice for information security controls".

[i.29] ISO/IEC 27004: "Information technology -- Security techniques -- Information security management -- Measurement".

[i.30] ETSI TR 103 305: "CYBER; Critical Security Controls for Effective Cyber Defence".

3 Definition of terms, symbols and abbreviations

3.1 Terms

Void.

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ACDC	Advanced Cyber Defence Centre
AS	Autonomous System
ATT&CK™	Adversarial Tactics, Techniques and Common Knowledge
CERT	Computer Emergency Response Team
CIF	Collection Intelligence Framework
COBIT	Control OBjectives for Information and related Technology
CPNI	Centre for the Protection of National Infrastructure
CSAF	Common Security Advisory Framework
CSIRT	Computer Security Incidence Response Team
CTI	Cyber Threat Intelligence
CVRF	Common Vulnerability Reporting Framework
CYBEX	Cybersecurity Information Exchange
CybOX™	Cyber Observable Expression
DHS	Department of Homeland Security
DoS	Denial of Service
DTCC	Depository Trust & Clearing Corporation
ENISA	European Union Agency for Network and Information Security
EU	European Union
FIRST	Forum of Incident Response and Security Teams
FS-ISAC	Financial Services ISAC
GS	Group Specification
HTTP	Hypertext Transfer Protocol
IDS	Identification Detection System
IETF	Internet Engineering Task Force
INC	INdiCators
INCH	INCident Handling
IODEF	Incident Object Description Exchange Format
IP	Internet Protocol
ISAC	Information Sharing and Analysis Center
ISACA	Information Systems Audit and Control Association
ISG	Industry Specification Group
ISI	Information Security Indicators
IT	Information Technology
ITU-T	International Telecommunication Union Telecommunication Standardization
JSON	JavaScript™ Object Notation
KPSI	Key Performance Security Indicators
MAEC™	Malware attribute enumeration and characterization
MILE	Managed Incident Lightweight Exchange
NIS	Network and Information Security
OASIS	Organization for the Advancement of Structured Information Standards
OMG	Object Management Group
OSSIM	Open Source Security Information Management
OTX	Open Threat eXchange
RID	Real-time Inter-network Defense
STIX™	Structured Threat Information Expression
TAXII™	Trusted Automated Exchange of Indicator Information
TTP	Tactics, Techniques and Procedures
US	United States
VERIS	Vocabulary for Event Recording and Incident Sharing

NOTE: CybOX™, STIX™ and TAXII™ are trademarks of the U.S. Government, licensed to OASIS. See https://www.oasis-open.org/committees/cti/ipr.php. MAEC™ is a trademark of The MITRE Corporation operating as a non-profit Federally Funded Research and Development Center (FFRDC) of the U.S. Department of Homeland Security. See http://maecproject.github.io/Legal/.

4 Means for exchanging structured cyber threat intelligence

4.1 Introduction

The need for the exchange of structured cyber threat intelligence grew in the 1990s in conjunction with increasing numbers of discovered exploits of network vulnerabilities and attacks. This led to a diverse array of initiatives and projects to develop structured expressions and associated protocols for the trusted exchange of information concerning those vulnerabilities and attacks, and remediation steps - which are described in the following clauses. These efforts and the resulting platforms have moved forward (or not) at significantly different scales, and involve specialized and sometimes vendor-oriented communities. The Financial Services Information Sharing and Analysis Center (FS-ISAC) and The Depository Trust & Clearing Corporation (DTCC) communities are especially significant and one of the EU NIS essential services sectors. The largest related standards activity - now consists of OASIS Technical Committee on Cyber Threat Intelligence (TC CTI) - and is still rapidly growing and evolving.

4.2 OASIS Cyber Threat Intelligence Technical Committee (TC CTI)

4.2.1 Introduction

The OASIS Cyber Threat Intelligence (CTI) TC was chartered to define a set of information representations and protocols to address the need to model, analyse, and share cyber threat intelligence. Three specifications were transitioned from the US Department of Homeland Security (DHS) for development and standardization under the OASIS open standards process: STIX™ (Structured Threat Information Expression), TAXII™ (Trusted Automated Exchange of Indicator Information), and CybOX™ (Cyber Observable Expression). The OASIS CTI Technical Committee remit includes:

- define composable information sharing services for peer-to-peer, hub-and-spoke, and source subscriber threat intelligence sharing models;
- develop standardized representations for campaigns, threat actors, incidents, tactics techniques and procedures (TTPs), indicators, exploit targets, observables, and courses of action;
- develop formal models that allow organizations to develop their own standards-based sharing architectures to meet specific needs.

TC CTI consists of a significant number of companies, government agencies, and institutes from around the world. New OASIS versions of the three initial platforms (STIX™, TAXII™, and CybOX™) were produced. Rather considerable material including running code is hosted on multiple design GitHubs. CybOX and MAEC™ were conflated into the TAXII™ and STIX 2.1 is under development STIX and TAXII versions 1.x have been depreciated. As of June 2018, the principal adopted standards consist of:

- STIX™ 2.0 Specification, July 2017 [i.4].
- TAXII™ 2.0 Specification, July 2017 [i.4].

The principal resource sites are:

- Documentation and examples: https://oasis-open.github.io/cti-documentation/
- Community tooling: https://oasis-open.github.io/cti-documentation/resources.html

- OASIS CTI TC: https://www.oasis-open.org/committees/cti/
- ATT&CK in STIX 2: https://github.com/mitre/cti

The value of STIX lies in its JSON language to describe Cyber Threat Intelligence, being designed for sharing, its very active and diverse community of developers and analysts, and publication of freely-available international standards by OASIS.

4.2.2 STIX 2.0

The objective of the Structured Threat Information Expression (STIX™) effort is to specify, characterize and capture cyber threat information. STIX addresses a full range of cyber threat use cases - including threat analysis, capture and specification of indicators, management of response activities and information sharing - to improve consistency, efficiency, interoperability and overall situational awareness.

The STIX use cases are depicted in figure 4.1, the intelligence model and expression groups in figure 4.2 and examples in figure 4.3.

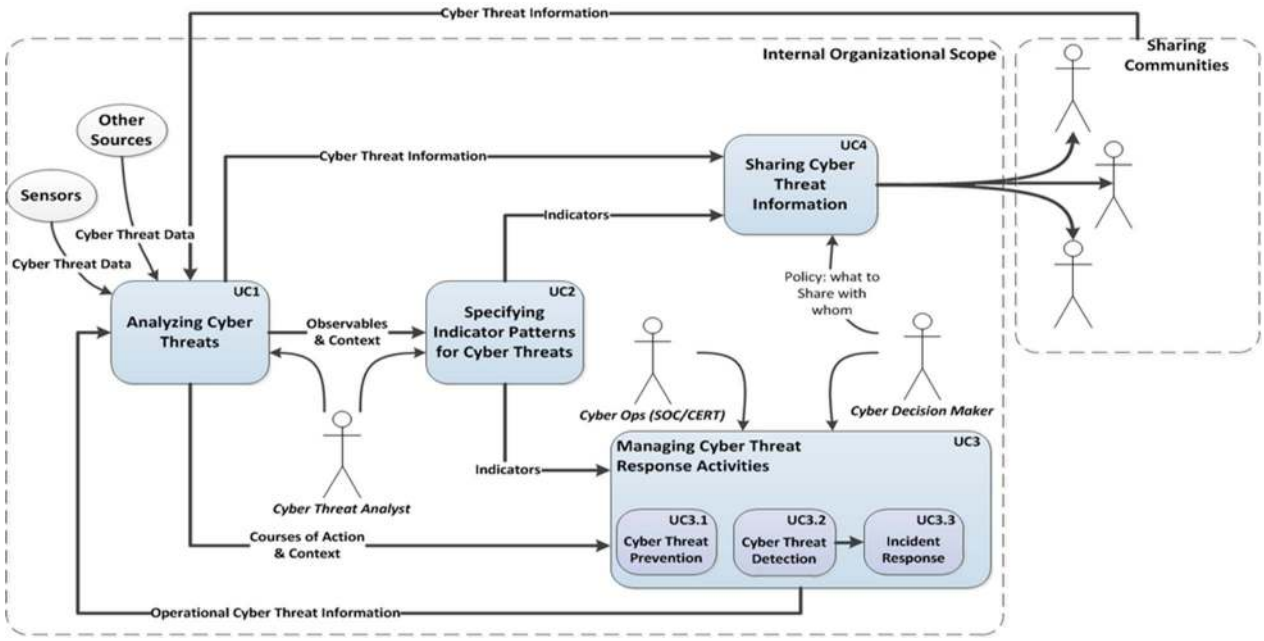


Figure 4.1: STIX use cases [i.4]

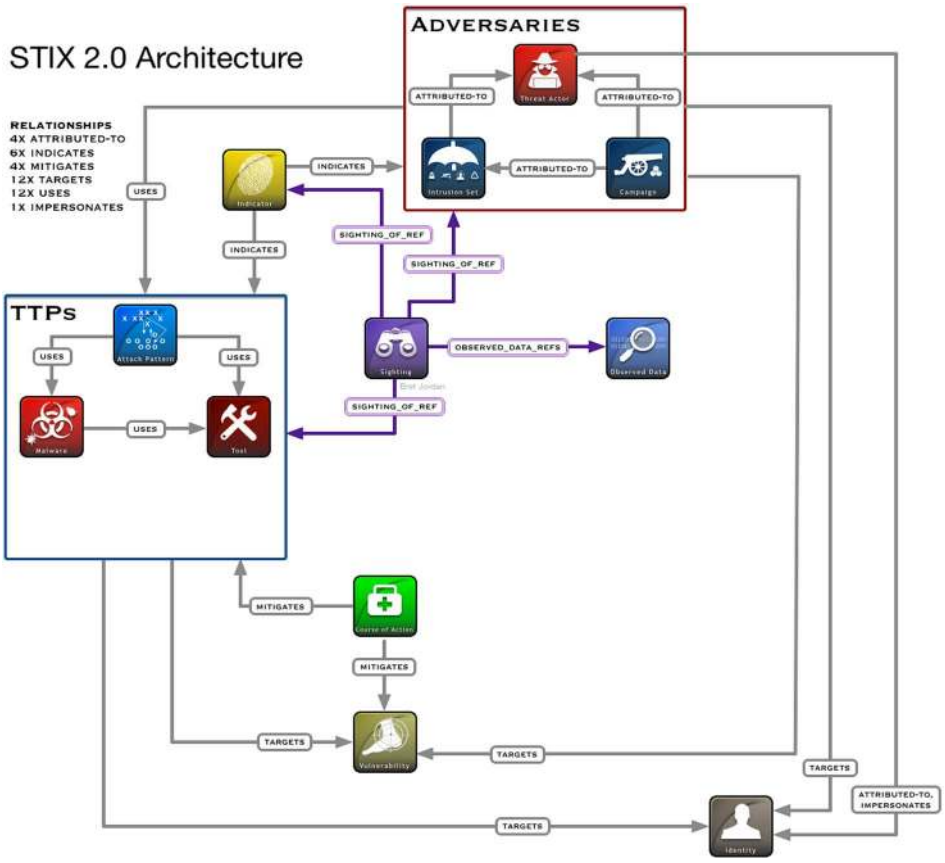


Figure 4.2: STIX 2.0 Architecture [i.4]

Object	Description
	A type of Tactics, Techniques, and Procedures (TTP) that describes ways threat actors attempt to compromise targets.
	A grouping of adversarial behaviors that describes a set of malicious activities or attacks that occur over a period of time against a specific set of targets.
	An action taken to either prevent an attack or respond to an attack.
	Individuals, organizations, or groups, as well as classes of individuals, organizations, or groups.
	Contains a pattern that can be used to detect suspicious or malicious cyber activity.
	A grouped set of adversarial behaviors and resources with common properties believed to be orchestrated by a single threat actor.

Object	Description
	A type of TTP, also known as malicious code and malicious software, used to compromise the confidentiality, integrity, or availability of a victim's data or system.
	Conveys information observed on a system or network (e.g., a IP address).
	Collections of threat intelligence focused on one or more topic such as a description of a threat actor, malware, or attack technique, including contextual details.
	Individuals, groups, or organizations believed to be operating with malicious intent.
	Legitimate software that can be used by threat actors to perfor attacks.
	A mistake in software that can be directly used by a hacker to gain access to a system or network.

Figure 4.3: STIX 2.0 Domain Objects [i.4]

STIX 2.0 disambiguates between Cyber Observable instances and patterns and defines a new patterning language, is based on SQL-92, bound to the STIX 2.0 Cyber Observable data model, and allows for the expression of a range of patterns, from very simple to more complex (including temporal logic). STIX 2.0 also introduces test-based validation that divides personas for different use cases and each persona will pass a series of tests to be found compatible.

4.2.3 STIX 2.1

STIX continues to evolve and new capabilities being included in version 2.1 are depicted in figure 4.4 and planned for completion in late 2018.

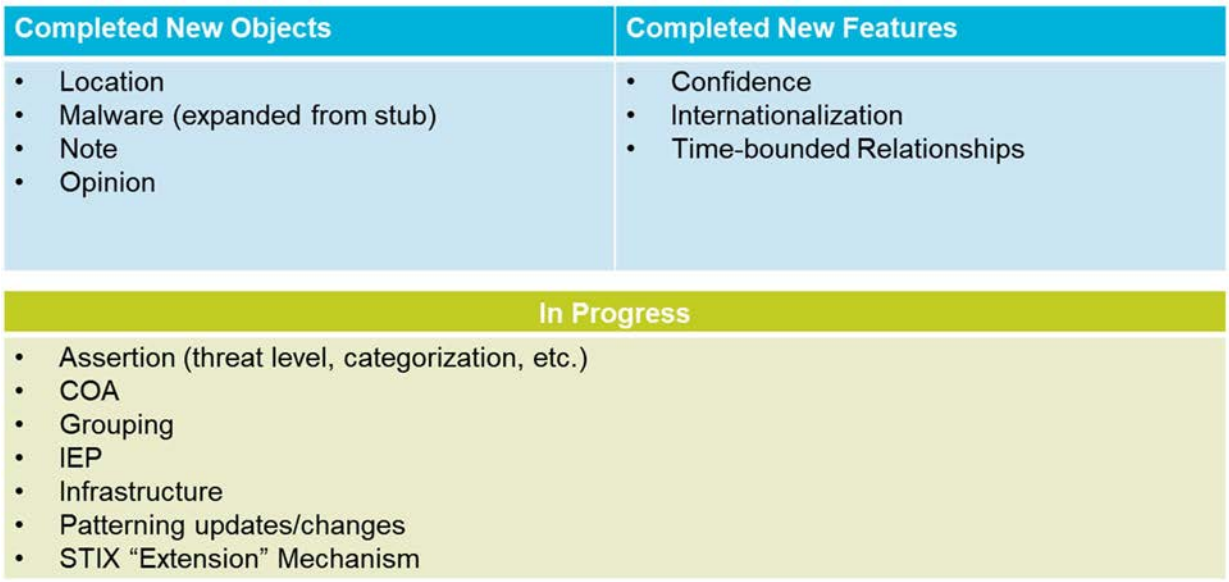


Figure 4.4: STIX 2.1 New Features [i.4]

4.2.4 Adversarial Tactics, Techniques and Common Knowledge in STIX 2.0

Adversarial Tactics, Techniques and Common Knowledge (ATT&CK™) is a globally-accessible knowledge base of adversary tactics and techniques, based on real-world observations of adversaries' operations and is increasingly being used by the community as a common way to describe adversary behaviour.

With ATT&CK, developers can use the well-known and documented STIX 2 object model, and can leverage APIs such as the Python STIX APIs to manipulate ATT&CK content. It also enables existing tools to be able to process data (e.g. visualization tools), and access via TAXII 2.

4.2.5 TAXII 2.0

Trusted Automated eXchange of Indicator Information (TAXII™) defines a set of services and message exchanges that, when implemented, sharing of actionable cyber threat information across organization and product/service boundaries. TAXII, through its member specifications, defines concepts, protocols and messages to exchange cyber threat information for the detection, prevention, and mitigation of cyber threats. The models supported by V1.1.1 as well as the specification components are shown in figures 4-5 and 4-6.

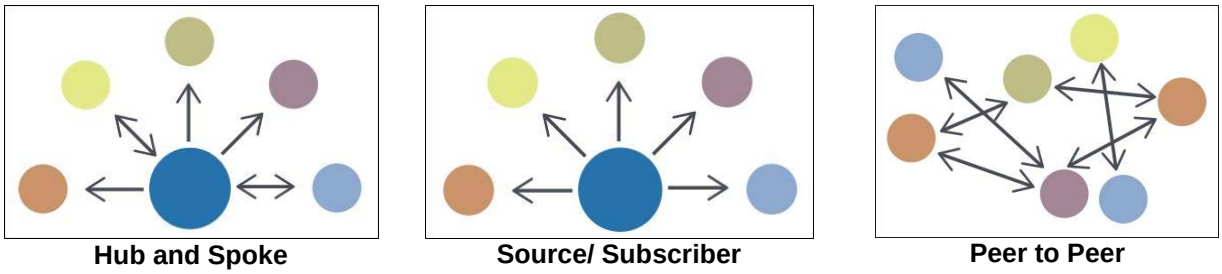


Figure 4.5: TAXII models supported [i.4]

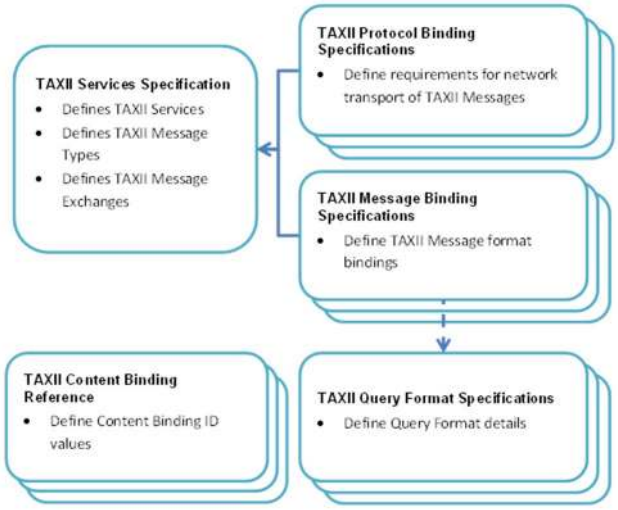


Figure 4.6: TAXII specification components [i.4]

TAXII 2.0 features include: Publish and Subscribe model over an HTTP RESTful interface; TAXII Servers are plumbing for CTI between TAXII Clients; each TAXII Server has some defined out-of-the box channels that clients can publish or subscribe. The model is depicted in figure 4.7.

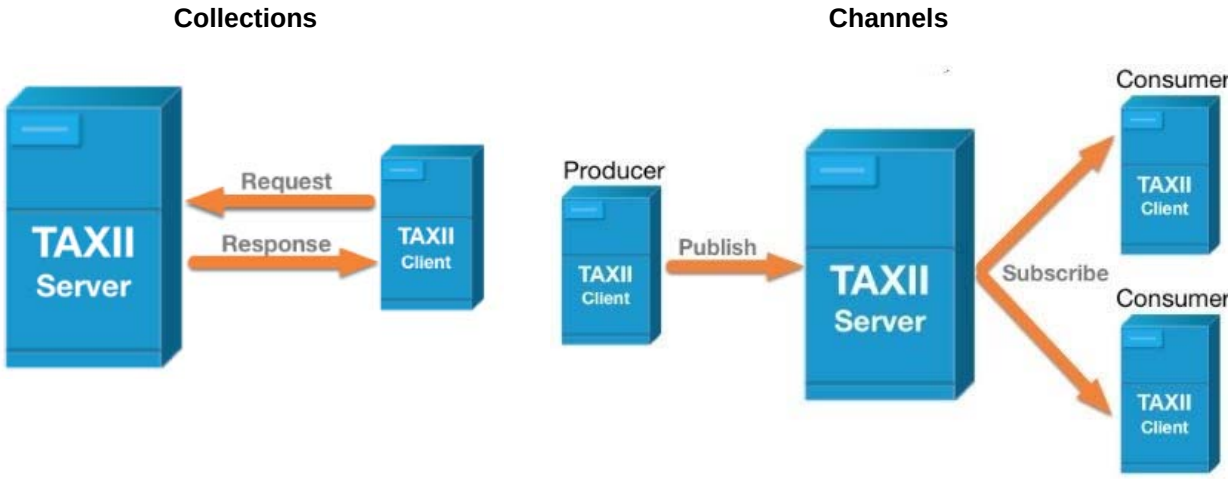


Figure 4.7: TAXII 2.0 proposed channel architecture [i.4]

4.3 IETF Managed Incident Lightweight Exchange Working Group (mile)

In the 1990s, the various network Computer Emergency Response Teams under the leadership of the Carnegie Mellon CERT, FIRST, SurfNet Netherlands, and similar organizations focussed on the need to structure threat information for exchanging among themselves. Circa 2006 an IETF working group known as INCH (Extended Incident Handling) was established for the purposes of developing specifications. It developed a number of guideline Internet Drafts for an incident description language, transport protocols, and other capabilities that were advanced under the name The Incident Object Description Exchange Format or IODEF. IODEF was also replicated by ITU-T.

In 2011, in response to an increasing need for updates and extensions to IODEF and related new tools, the Managed Incident Lightweight Exchange Working Group (mile) was chartered and has been active since. The working group develops standards to support computer and network security incident management. It describes its role as:

> "*The Managed Incident Lightweight Exchange (MILE) working group develops standards to support computer and network security incident management; an incident is an unplanned event that occurs in an information technology (IT) infrastructure. An incident could be a benign configuration issue, IT incident, a system compromise, socially engineered phishing attack, or a denial-of-service (DoS) attack, etc. When an incident is detected, or suspected, there may be a need for organizations to collaborate. This collaboration effort may take several forms including joint analysis, information dissemination, and/or a coordinated operational response. Examples of the response may include filing a report, notifying the source of the incident, requesting that a third party resolve/mitigate the incident, sharing select indicators of compromise, or requesting that the source be located. By sharing indicators of compromise associated with an incident or possible threat, the information becomes a proactive defense for others that may include mitigation options."* [i.5].

The Incident Object Description Exchange Format (IODEF) defines an information framework to represent computer and network security incidents [i.5]:

- IETF RFC 5070 [i.14]: "Incident Object Description Exchange Format (IODEF)".
- IETF RFC 6545 [i.15]: "Real-time Inter-network Defense (RID)" defines a protocol to facilitate sharing computer and network security incidents.
- IETF RFC 6546 [i.16]: "Transport of Real-time Inter-network Defense (RID) Messages over HTTP/TLS".

The ITU-T Study Group 17 replicated IETF RFC 6046 [i.21] (RID) and IETF RFC 6046 [i.21] (RID) as Recommendation ITU-T X.1581 [i.6].

4.4 CSIRTGadgets Collective Intelligence Foundation (CIF)

The CSIRT Gadgets Foundation was founded with a mission to directly engage both public and private sector CSIRTs as a means for evolving the internet into a more secure and resilient ecosystem. The Foundation has been organized as a non-profit organization in the United States. The Foundation promotes the development and stewardship of assets such as software, algorithms and best common practices that enable CSIRTs execute their missions. One of its existing initiatives is known as the Collective Intelligence Framework funded by the U.S. National Science Foundation for use and development among the university educational community.

CIF allows to combine known malicious threat information from many sources and use that information for identification (incident response), detection (IDS) and mitigation (null route). The most common types of threat intelligence warehoused in CIF are IP addresses, domains and URLs that are observed to be related to malicious activity. CIF is used by the Research and Education Networking Information Sharing and Analysis Center (REN-ISAC) and the Anti-Phishing Working Group. A Foundation information site is available at http://csirtgadgets.org/.

4.5 EU Advanced Cyber Defence Centre (ACDC)

On an even larger scale than the CIF project described in clause 4.4, the European Commission helped initiate and fund the Advanced Cyber Defence Centre project from early 2013 to mid-2015. The objective was to establish a sustainable European centre for cyber defence, building on 8 networked support centres and one clearing house deployed during the project and enlarging the cyber-protection scope beyond botnets. ACDC unites a community of 28 organizations from 14 countries, including Internet Service Providers, CERTs, law enforcement agencies, IT providers, National Research and Education Networks (NRENs), academia and critical infrastructure operators.

In the initial phase of the projects, there was an active threat information sharing specifications group that made use of existing platforms via a Tool Group. The project ended in July 2015.

4.6 AbuseHelper

AbuseHelper is an open-source project initiated by CERT.FI and CERT.EE with Clarified Networks to automatically process incidents notifications. Its use has been encouraged by ENISA as a modular, potentially scalable and robust framework to help in abuse handling. With Abuse Helper one can retrieve Internet Abuse Handling related information via several sources, one can then aggregate that information based on different keys, such as numbers or country codes and send out reports in different formats, via different transports and using different timings.

4.7 OMG Threat Modelling Working Group

The Object Management Group has several initiatives related to the sharing of cyber threat information. The most prominent is a proposal for a combined risk-threat information model that incorporates STIX (among other things). It is expected to cover a broader scope (cyber and physical, threat and risk) in order to coordinate across these domains but does not seek to re-define a model within the domain to the low level that STIX and CybOX™. A cross domain Threat and Risk Community site that builds on OASIS CTI platforms exists at www.threatrisk.org.

4.8 ITU-T SG17

The Cybersecurity Rapporteur group within ITU-T Study Group 17 began in 2009 to develop a comprehensive initiative to identify and in some cases replicate structured cybersecurity information sharing platforms. The general framework was designated CYBEX (Cybersecurity Information Exchange) and an extensive series of specifications have been prepared [i.6]:

- X.1500: "Overview of cybersecurity information exchange".
- X.1500.1: "Procedures for the registration of arcs under the object identifier arc for cybersecurity information exchange".
- X.1520: "Common vulnerabilities and exposures".
- X.1521: "Common vulnerability scoring system".
- X.1524: "Common weakness enumeration".
- X.1525: "Common weakness scoring system".
- X.1526: "Language for the open definition of vulnerabilities and for the assessment of a system state".
- X.1528: "Common platform enumeration".
- X.1528.1: "Common platform enumeration naming".
- X.1528.2: "Common platform enumeration name matching".
- X.1528.3: "Common platform enumeration dictionary".
- X.1528.4: "Common platform enumeration applicability language".
- X.1541: "Incident object description exchange format".
- X.1542: "Session information message exchange format".
- X.1544: "Common attack pattern enumeration and classification".
- X.1546: "Malware attribute enumeration and characterization".
- X.1550: "Access control models for incidents exchange networks".
- X.1570: "Discovery mechanisms in the exchange of cybersecurity information".
- X.1580: "Real-time inter-network defence".

- X.1581: "Transport of real-time inter-network defence messages".
- X.1582: "Transport protocols supporting cybersecurity information exchange".

Current new threat information exchange platforms being developed by the ITU-T Cybersecurity group include the following [i.6]:

- X.metric, Metrics for evaluating threat and resilience in cyberspace.
- X.ucstix, Use Cases for Structured Threat Information Expression (STIX).
- X.fgati, "Framework and Guidelines for Applying Threat Intelligence in Telecom Network Operation".

4.9 Open Threat Exchange™ (OTX™)

AlienVault is the developer of the Open Source Security Information Management (OSSIM). Its vision is for companies and government agencies to gather and share relevant, timely, and accurate information about new or ongoing cyberattacks and threats as quickly as possible to avoid major breaches (or minimize the damage from an attack). AlienVault's Open Threat Exchange™ (OTX) is its principle platform.

NOTE: Open Threat Exchange™ is the trade name of a product supplied by AlienVault. This information is given for the convenience of users of the present document and does not constitute an endorsement by ETSI of the product named. Equivalent products may be used if they can be shown to lead to the same results."

AlienVault OTX™ provides open access to a global community of threat researchers and security professionals. It delivers community-generated threat data, enables collaborative research, and automates the process of updating a security infrastructure with threat data from any source. OTX enables anyone in the security community to actively discuss, research, validate, and share the latest threat data, trends, and techniques, strengthening defences while helping others do the same.

4.10 OpenIOC Framework

The OpenIOC framework is an information exchange specification that describes Indicators of Compromise and is managed by an open developer community. OpenIOC addresses a narrow use case (observable patterns for Indicators of Compromise) and represents a partial solution to part of the overall cyber threat information problem, but does not fully address the needs of a holistic cyber threat intelligence information model.

4.11 VERIS Framework

Another common language for describing security incidents is the Vocabulary for Event Recording and Incident Sharing (VERIS). It addresses a narrow use case and represents a partial solution to part of the overall cyber threat information problem but does not fully address the needs of a holistic cyber threat intelligence information model. The VERIS community site is available at www.veriscommunity.net. In addition, the published format is available on GitHub at https://github.com/vz-risk/veris.

4.12 ETSI ISI (Information Security Indicators) ISG

In 2011, an Industry Specification Group was created by ETSI to undertake several activities relating to Information Security Indicators, including a Security Event Classification Model and its implementation [i.7]. Preliminary work on information security indicators was done by the French Club R2GS. The first public set of the ISI standards (security indicators list and event model) were released in April 2013 and now includes a set of five specifications:

- ETSI GS ISI 001-1 [i.8]: "Information Security Indicators (ISI); Indicators (INC); Part 1: A full set of operational indicators for organizations to use to benchmark their security posture".
- ETSI GS ISI 001-2 [i.9]: "Information Security Indicators (ISI); Indicators (INC); Part 2: Guide to select operational indicators based on the full set given in part 1".

- ETSI GS ISI 002 [i.10]: "Information Security Indicators (ISI); Event Model A security event classification model and taxonomy".
- ETSI GS ISI 003 [i.11]: "Information Security Indicators (ISI); Key Performance Security Indicators (KPSI) to evaluate the maturity of security event detection".
- ETSI GS ISI 004 [i.12]: "Information Security Indicators (ISI); Guidelines for event detection implementation".
- ETSI GS ISI 005 [i.13]: "Information Security Indicators (ISI); Guidelines for security event detection testing and assessment of detection effectiveness".

Although the term Information Security Indicator is not defined, an "indicator" is defined as a "measure that provides an estimate or evaluation of specified attributes derived from an analytical model with respect to a defined information need". These indicators provide the basis to switch from a qualitative to a quantitative culture in IT Security Scope of measurements: External and internal threats (attempt and success), user's deviant behaviours, nonconformities and/or vulnerabilities (software, configuration, behavioural, general security framework). ISO/IEC 27001 [i.27], ISO/IEC 27002 [i.28] and ISO/IEC 27004 [i.29], plus ISACA COBIT and the Critical Security Controls found in ETSI TR 103 305 [i.30] are all normative for implementation of the specifications, and the ISI specifications provide useful descriptions of the relationships among the various terminologies and models. A useful summary of basic terminology are provided in figure 4.8.

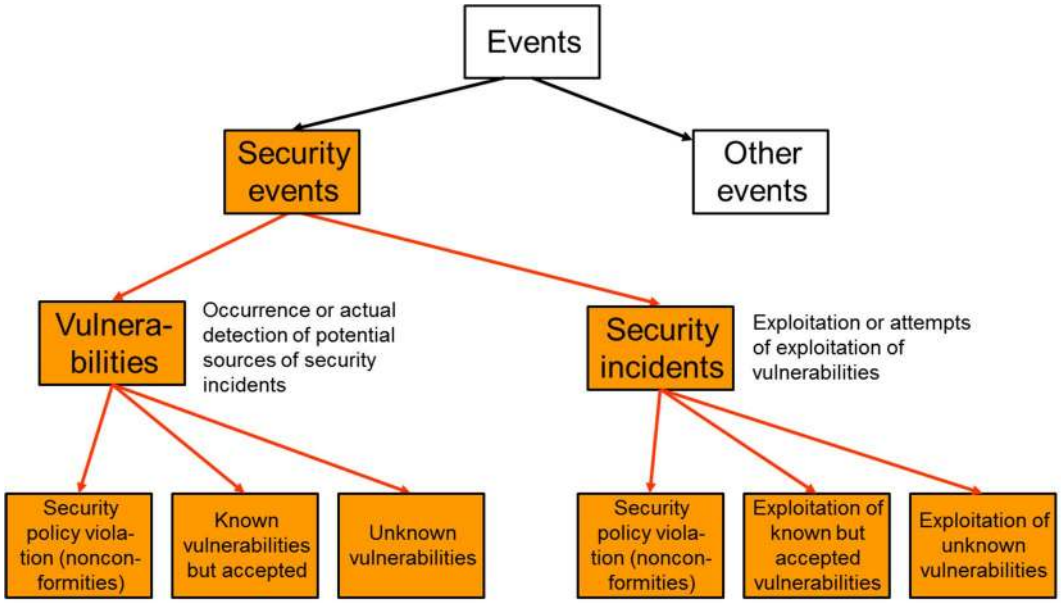


Figure 4.8: Relationships between different kinds of events [i.8]

4.13 OASIS Common Security Advisory Framework (CSAF) Technical Committee

The OASIS Common Security Advisory Framework (CSAF) Technical Committee was created in 2017 to further develop the Common Vulnerability Reporting Framework (CVRF) developed through an industry consortium. Several technology vendors (including major Internet backbone providers) have produced advisories in the CVRF format, and many organizations successfully consume this information (https://www.oasis-open.org/apps/org/workgroup/csaf/index.php). CSAF subsequently published CVRF version 1.2 in September 2017. (http://docs.oasis-open.org/csaf/csaf-cvrf/v1.2/cs01/csaf-cvrf-v1.2-cs01.html). The CVRF language which supports creation, update, and interoperable exchange of security advisories as structured information on products, vulnerabilities and the status of impact and remediation among interested parties. Open repositories of the documentation and code are available (https://oasis-open.github.io/csaf-documentation/ and https://github.com/oasis-open/csaf-documentation).

CVRF features compatibility with other extensively used vulnerability standards such as CVE and CVSS. It is also being integrated into the STIX Framework and a JSON schema for CVRF 2.0 is being developed.

Annex A: Bibliography

- Farnham and Leune: "Tools and Standards for Cyber Threat Intelligence Projects," SANS Institute InfoSec Reading Room, 14 October 2013.
- ENISA: "Standards and tools for exchange and processing of actionable information", November 2014,
- Jerome Athias: "Cyber Threat Intelligence Sharing Standards", RSA Conference 2015, Abu Dhabi.
- Struse: "STIX 2 - Putting Cyber Threat Intelligence to Work" MITRE, May 2018.

NOTE: See also ATT&CK at https://attack.mitre.org.

History

Document history		
V1.1.1	August 2016	Publication
V1.2.1	September 2019	Publication